

## **System Architecture Report**

Date: December 7, 2025

Network Segment: CTF-Lab (Isolated LAN)

Subnet Mask: 255.0.0.0 (/8) — Configured to allow routing between 10.0.x.x and 10.1.x.x.

---

## 1. Network Topology & Asset Inventory

The environment consists of three Windows Server nodes representing a multi-domain Active Directory Forest and one Linux attacker node.

| Hostname | Role                    | Operating System     | IP Address | Domain         | Notes                                               |
|----------|-------------------------|----------------------|------------|----------------|-----------------------------------------------------|
| DC01     | Root Domain Controller  | Windows Server 2019  | 10.0.0.10  | MEGA.LOCAL     | Forest Root. The ultimate target.                   |
| DC02     | Child Domain Controller | Windows Server 2019  | 10.1.0.10  | SUB.MEGA.LOCAL | Controls the Child Domain. Initial target.          |
| CL02-HR  | Workstation             | Windows Server 2019* | 10.1.0.100 | SUB.MEGA.LOCAL | Simulated Windows 10 Client. Used by HR department. |
| Kali     | Attacker Node           | Kali Linux           | 10.0.0.5   | N/A            | External threat actor.                              |

*\*Note: CL02-HR runs Windows Server 2019 but is configured to behave as a client workstation (Windows 10 equivalent) for this scenario.*

---

## 2. Domain Architecture & Trust Relationships

The environment simulates a corporate Enterprise Forest structure.

- Forest Root: MEGA.LOCAL (Managed by DC01).
  - Child Domain: SUB.MEGA.LOCAL (Managed by DC02).
  - Trust Relationship: A bi-directional, transitive Parent-Child Trust exists between the two domains.
    - *Security Implication:* Administrators in the Root domain effectively control the Child domain. However, Child Administrators typically cannot control the Root, unless specific vulnerabilities (like SID History Injection) are exploited.
- 

## 3. User Credentials & Roles

Infrastructure Administrators (Out of Scope for CTF Play)

*Used for lab setup and maintenance only.*

- MEGA\Administrator: RootPass123! (Enterprise Admin)
- SUB\Administrator: RootPass123! (Domain Admin)
- CL02-HR\Administrator: LocalPass123! (Local Machine Admin)

CTF Scenario Actors (In Scope)

*Credentials discoverable during the engagement.*

| Username         | Password     | Privileges                      | Role in Attack Chain                                                                           |
|------------------|--------------|---------------------------------|------------------------------------------------------------------------------------------------|
| SUB\hr_juniors   | Welcome2025! | Local Admin (on CL02-HR)        | Initial Access. Credentials found in open share. Used to pivot to the workstation.             |
| SUB\helpdesk_guy | P@ssw0rd     | Standard User (with ACL rights) | Privilege Escalation. Credentials cached on CL02-HR. Has GenericWrite on Domain Admins.        |
| SUB\it_admin     | N/A          | Fake User                       | Red Herring. Found in the config file, but the username is invalid (leads to RID Brute Force). |

#### 4. Vulnerability Configuration Map

The following misconfigurations were intentionally deployed to create the exploit path.

##### Vulnerability 1: Information Disclosure (DC02)

- Configuration: The folder C:\Public is shared as Public.
- Policy Weakness:
  - Group Policy allows "Anonymous Access" to the Public share.
  - Group Policy allows "Guest" and "Anonymous Logon" to enumerate shares.
- Artifact: A file named printer\_conf.xml contains the valid password Welcome2025! (associated with the wrong username it\_admin).

##### Vulnerability 2: Lateral Movement (CL02-HR)

- Configuration: The domain group SUB\Domain Users was added to the Local Administrators group on the workstation CL02-HR (10.1.0.100).
- Impact: Since hr\_juniors is a Domain User, they automatically become a Local Administrator on this specific machine.
- Artifact: helpdesk\_guy previously logged into this machine interactively, leaving his DCC2 password hash in the LSASS memory/registry.

##### Vulnerability 3: ACL Misconfiguration (Active Directory)

- Configuration: The user helpdesk\_guy was granted GenericWrite (or FullControl) permissions on the Domain Admins group object in Active Directory.
- Persistence: helpdesk\_guy was added to the AdminSDHolder object permissions to prevent the SDProp process from automatically reverting this vulnerability.
- Impact: This allows a standard user (helpdesk\_guy) to add any user (including hr\_juniors) to the Domain Admins group.

##### Vulnerability 4: Unfiltered Trust (Forest)

- Configuration: The default Parent-Child trust configuration allows SID History to travel across the trust boundary.
  - Impact: A compromised Child Domain Admin can forge a Kerberos Ticket (Golden Ticket) with the SID History field set to the Parent Domain's Enterprise Admins SID (-519), granting full control over the Root Domain.
- 

## 5. Attacker Machine Configuration

To successfully execute the attack, the Kali Linux machine requires the following configuration:

- Network: Connected to the CTF-Lab LAN Segment.
- Static IP: 10.0.0.5 (Netmask /8).
- Time Sync: NTP synchronized with 10.0.0.10 (Crucial for Kerberos).
- DNS / Hosts File:

Plaintext

10.0.0.10 dc01.mega.local mega.local

10.1.0.10 dc02.sub.mega.local sub.mega.local